

BEFORE Placeholder

AFTER

# Operating Model Overview — Third-Party Security Program (Engineering-led)

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: \_\_\_\_\_

Review cadence: Annually

## 1. Purpose

This operating model describes how the Third-Party Security Program runs day-to-day to ensure suppliers are tiered, assessed, onboarded, monitored, and offboarded with controls proportionate to risk and aligned to secure-by-design engineering practices.

## 2. Scope

This operating model applies to all third parties that:

- process/store/transmit organisational data, and/or
- integrate/connect to organisational systems, and/or
- have privileged access, and/or
- support business-critical services.

## 3. Operating model principles

- **Engineering-led:** prioritise technical controls and verifiable validation over paper-only assurance.

- **Tiered and proportionate:** apply stronger requirements to Critical suppliers and lighter-touch checks to Low suppliers.
- **Standard patterns:** use approved integration patterns to reduce bespoke security decisions.
- **Explicit trade-offs:** exceptions are documented, compensated, approved, and time-bound.
- **Audit-ready by design:** decisions, approvals, and evidence are recorded as part of normal delivery.

## 4. Core components

### 4.1 People (roles)

Minimum roles engaged:

- Business Service Owner
- Third-Party Security Program Owner
- Security Engineering/Architecture
- Procurement
- Legal Counsel
- DPO/Privacy Officer
- IT/Platform Owner
- Operations (where applicable)
- Senior Residual Risk Acceptor (for material Critical decisions)

Roles and responsibilities are defined in ``program-charter/05-roles-and-responsibilities-raci.md``.

### 4.2 Process (lifecycle)

End-to-end process is defined in:

- ``operating-model/02-process-flow-intake-to-onboarding.md``

Lifecycle stages:

- Intake & tiering → Due diligence → Contracting → Onboarding → Monitoring → Offboarding

## 4.3 Policy and standards

Normative standards for the program:

- Governance & approvals: ``program-charter/02-governance-approvals-escalation.md``
- Minimum requirements by tier: ``program-charter/03-minimum-security-requirements-by-tier.md``
- Exceptions standard: ``program-charter/04-policy-exceptions-standard.md``
- Data retention: ``program-charter/data-retention-policy.md`` (or equivalent name)

## 4.4 Artifacts (toolkit outputs)

Key artifacts produced/maintained:

- Supplier intake form and tiering record (``tiering-model/``)
- Evidence packs by tier (``evidence-packs/``)
- Control baselines + validation steps (``control-baselines/``)
- Integration patterns (``integration-patterns/``)
- Offboarding checklist (``offboarding/`` or root doc)
- Exception requests + register (``program-charter/``)
- Dashboards and metrics (``metrics/``)

## 5. Tiering and routing rules (summary)

Suppliers are classified as:

- **Critical:** business critical and/or privileged access/production influence and/or sensitive data and/or elevated connectivity/fourth-party risk
- **Important:** meaningful integration and/or limited sensitive data without Critical triggers
- **Low:** minimal exposure and low business impact

Routing outcomes:

- Evidence pack depth and control baselines are selected by tier.
- Any personal data processing triggers DPO/Privacy Officer engagement.

## 6. Decision rights (summary)

- Standard decisions are taken in the Third-Party Security Review (TPSR).
- Material Critical-tier residual risk decisions are escalated to the Senior Risk Acceptance Forum (generic) as defined in governance.
- Exceptions to MUST requirements require documented compensating controls, approvals, and expiry dates.

## 7. Cadence

Minimum cadences:

- TPSR: weekly (or as needed for onboarding)
- Critical supplier reassessment: at least annually (or on trigger events)
- Metrics dashboard: monthly
- Policy/standards review: annually

(Exact frequencies may be adjusted by organisational policy and supplier risk profile.)

## 8. Inputs and outputs

### Inputs

- Business requirement and supplier scope
- Integration design requirements
- Supplier evidence and contractual positions
- Privacy scope (if applicable)

### Outputs

- Tier classification and decision record
- Approved onboarding pattern and validated controls
- Exceptions (if any) with expiry and remediation plan
- Ongoing monitoring actions and KPI/KRI reporting
- Offboarding evidence (access removed; data return/deletion confirmed)

## 9. Escalation and blocking rules (minimum)

- Critical suppliers with unmet MUST requirements are blocked unless an approved exception exists with compensating controls and expiry.
- Requests involving inbound connectivity or production privileged access are treated as Critical unless explicitly justified and approved.

## 10. Definitions

Key definitions are maintained in ``program-charter/01-third-party-security-program-charter.md``.